

closure_evidence_20260922

BOB-171 closure evidence — 2026-09-22

Fix (both sites, identical policy — a trusted-proxy CIDR allowlist)

download-proxy/src/api/rate_limit.py (:7187):

`_trusted_proxy_networks()` (line ~162), `_peer_is_trusted_proxy()` (line ~188), `_client_key()` (line ~200, the fix): reads the raw peer first; if `TRUST_FORWARDED_FOR` is off → raw peer (unchanged); if on but the peer is not in `TRUSTED_PROXY_CIDRS` → raw peer; if on and the peer IS trusted → **rightmost** XFF element (was leftmost).

plugins/download_proxy.py (:7186, built to exact policy parity):

`_rl_trusted_proxy_networks()` (~422), `_rl_peer_is_trusted_proxy()` (~447), `_rate_limit_client()` (~658) — identical logic, mirrored.

Design decision recorded honestly: the item names two options (rightmost- minus-N-trusted-hops vs. a trusted-proxy CIDR allowlist) as an open deployment-topology choice with no operator decision on record. The implementing agent chose the CIDR allowlist as the safer zero-config default (degrades to `TRUST_FORWARDED_FOR`-off behavior when `TRUSTED_PROXY_CIDRS` is unset) — both source files carry a block comment stating this explicitly as an AGENT-CHOSEN implementation decision, not an operator-made one, and note an operator can swap in hop-counting if their real topology needs chained trusted proxies.

RED evidence (pre-fix leftmost parsing, reproduced from the exact pre-fix source)

```
RED (pre-fix _client_key) keys across rotating forged XFF:
['1.1.1.1', '2.2.2.2', '9.9.9.9', '6.6.6.6']
EXPECTED FAILURE (RED confirmed): resolved bucket key rotated:
['1.1.1.1', '2.2.2.2', '9.9.9.9', '6.6.6.6'] -- this is the
BOB-171 bypass
```

GREEN + paired-mutation + negative-control (independently re-verified this session)

```
$ .venv/bin/python -m pytest tests/unit/
test_rate_limit_client_identity_bob171.py \
    tests/security/
test_rate_limit_download_proxy_trusted_proxy_bob171.py \
    tests/security/test_rate_limit_download_proxy.py -v --no-cov
...
29 passed in 18.11s
```

Includes, per site:

```
test_green_rotating_leftmost_xff_does_not_rotate_the_bucket_key,
test_green_key_is_not_any_forged_leftmost_value (GREEN);
test_mutation_restoring_leftmost_parsing_fails (paired mutation —
the byte-for-byte pre-fix logic run against the same scenario is asserted
to genuinely fail, proving the GREEN test isn't trivially satisfied);
test_negative_control_flag_off_ignores_xff_entirely,
test_negative_control_default_env_state_ignores_xff,
test_flag_on_but_empty_allowlist_still_ignores_xff,
test_flag_on_but_peer_outside_allowlist_ignores_xff (all four
negative controls — XFF ignored entirely, keying falls back to raw peer,
no false-positive honoring introduced).
```

Also re-ran the full pre-existing tests/security/
test_rate_limit_download_proxy.py suite (13 tests) alongside — all
pass, no regression, including
test_per_ip_isolation_under_explicit_forwarded_for_optin which
needed one line added (TRUSTED_PROXY_CIDRS="127.0.0.1/32", its real
connecting peer) since it previously set TRUST_FORWARDED_FOR=1 alone
with no allowlist — exactly the vulnerable contract this fix closes —
and now needs an explicitly-trusted proxy to keep exercising per-IP
isolation.

Honest scope boundary (stated in-source, not silenced)

Closes the header-forgery bypass. Does not make per-IP limiting fair behind NAT, where many real users legitimately share one address — out of scope.

git diff –stat

```
download-proxy/src/api/rate_limit.py          | 115 ++++++++
+++++----
plugins/download_proxy.py                      | 119 ++++++++
+++++----
tests/security/test_rate_limit_download_proxy.py | 11 +-
3 files changed, 205 insertions(+), 40 deletions(-)
```

Plus 2 new untracked test files (14 new tests total across both sites).